1. Introduction et Objectifs

L'objectif de ce TP était de passer d'une posture offensive à une posture de **gestionnaire de vulnérabilités**. Nous avons utilisé **Nessus Essentials**, le standard de l'industrie, pour identifier automatiquement les faiblesses de sécurité sur deux machines cibles.

Objectifs spécifiques :

- Installer et configurer Nessus sur Kali Linux.
- Scanner une machine **Ubuntu (192.168.56.10)** et une machine **Windows (192.168.56.20)**.
- Identifier les CVE (Common Vulnerabilities and Exposures) et les mauvaises configurations.
- Analyser les scores de sévérité (CVSS).

2. Méthodologie et Mise en œuvre

A. Préparation de l'environnement

Le scanner a été déployé sur Kali Linux via les commandes suivantes :

Bash
```
sudo dpkg -i Nessus-*.deb
sudo systemctl start nessusd
```

L'accès à l'interface de gestion s'est fait via le navigateur à l'adresse `https://localhost:8834`.

B. Configuration du Scan

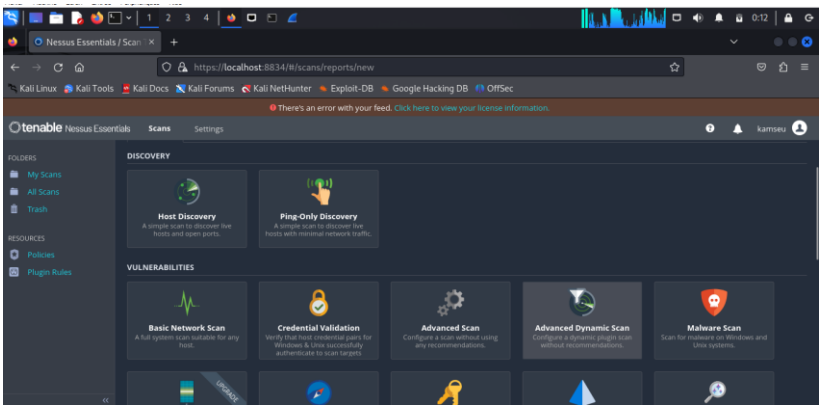
Un scan de type **"Basic Network Scan"** a été configuré avec les paramètres suivants :

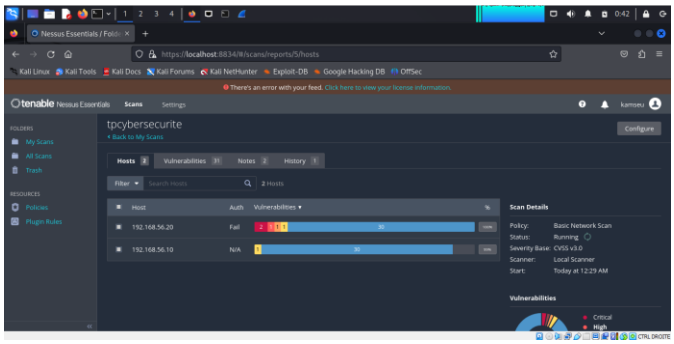
- **Nom du projet :** `tpcybersecurite`
- **Cibles :** `192.168.56.10`, `192.168.56.20`
- **Base de sévérité :** CVSS v3.0

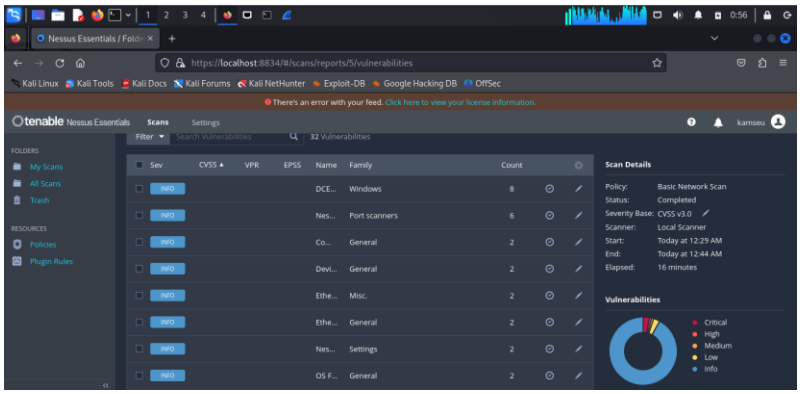
3. Analyse des Résultats du Scan

D'après les captures d'écran du tableau de bord (`tp5.png` et `tp3.png`), voici l'état des lieux :

A. Synthèse par Hôte







B. Observations Clés

1. **Échec d'authentification (Host .20) :** Nessus indique un statut "Fail" pour l'authentification sur la machine Windows. Cela signifie que le scan est **non-authentifié**. Le scanner ne voit que ce qui est exposé sur le réseau, les vulnérabilités réelles pourraient être plus nombreuses si un scan local (avec identifiants) était réalisé.
2. **Gravité :** La machine Windows présente un profil de risque plus élevé avec **2 vulnérabilités critiques**.
3. **Enumération :** Le scan a permis d'identifier des services via "DCE Services Enumeration" et "Nessus SYN scanner", confirmant que les ports sont ouverts et répondent aux requêtes.

4. Interprétation et Recommandations

Chaque vulnérabilité détectée par Nessus fournit trois informations cruciales pour l'entreprise :

- **Le score CVSS :** Pour prioriser les actions (on traite le Critique en priorité absolue).
- **La CVE :** L'identifiant unique de la faille pour la recherche documentaire.
- **La Solution :** Nessus propose directement des correctifs (patchs, modifications de registre ou mises à jour de configuration).

Plan d'action suggéré :

1. **Correction immédiate :** Appliquer les patchs de sécurité sur l'hôte `192.168.56.20` pour éliminer les 2 failles critiques.
2. **Investigation :** Analyser pourquoi l'authentification a échoué sur Windows (vérifier les services SMB ou les comptes de scan).

3. **Hardening :** Désactiver les services inutiles énumérés lors du scan pour réduire la surface d'attaque.

B. Lien avec le monde professionnel

Ce travil simule exactement les missions quotidiennes des métiers suivants :

- Auditeur sécurité : pour évaluer la santé technique d’une infrastructure
- Pentester :pour identifier les points d’entrée potentiels avant une intrusion
- Analyste SOS : pour surveiller et durcir les systèmes contr les menaces connues

5. Conclusion

Ce TP a permis de démontrer l'efficacité d'un scanneur de vulnérabilités pour obtenir une visibilité immédiate sur l'exposition d'un parc informatique. Pour un **SOC** ou un **auditeur**, cet outil est indispensable pour passer d'une sécurité réactive à une sécurité proactive.